PRIVARO

Privacy Infrastructure for Enterprise AI

Technical Architecture Overview

Enterprise AI Governance · Privacy by Design · Blockchain Evidence

iBS INTEGRATED	TOKENS VAULT	PRODUCTION	
~50ms	100%	SHA-512	Fantom
Proxy latency	PII coverage	Audit hash	Blockchain

Version 3.0 · March 2026 · iCommunity Labs · privaro.io

Table of Contents

1. Executive Summary
2. The PII Gap in Enterprise AI
  2.1 The AI Agent Risk
  2.2 Threat Model Overview
3. Architecture Overview
  3.1 Architecture Diagram
4. Data Flow — Request Lifecycle
5. Tokens Vault
  5.1 Vault Architecture
  5.2 Vault Event Lifecycle — UPDATED v3.0
  5.3 Reveal Flow — UPDATED v3.0
  5.4 Revoke Flow — UPDATED v3.0
6. Database Schema
7. Blockchain Evidence Layer (iBS)
  7.1 Certification Details
  7.2 Organization Signature Model
  7.3 Vault Access Certification
  7.4 Blockchain Verification Links — NEW v3.0
8. GDPR Export & DPO Report
9. Regulatory Compliance
10. Enterprise Use Cases
11. Role & Access Model — UPDATED v3.0
12. Internationalization (i18n) — NEW v3.0
13. Competitive Landscape
14. SLAs & Technical Guarantees
15. Roadmap — UPDATED v3.0
16. Architecture Principles

1 Executive Summary

Privaro is an enterprise AI governance infrastructure that operates as a transparent privacy proxy between enterprise applications and Large Language Models (LLMs). Every prompt passes through Privaro's semantic detection engine before reaching any AI provider — sensitive personal data is detected, tokenized, and replaced with pseudonymous placeholders. The LLM never sees real PII.

Every PII interception event is recorded as an immutable audit entry and cryptographically certified on the Fantom Opera Mainnet blockchain via iBS (iCommunity Blockchain Solutions), providing organizations with verifiable proof of GDPR Art.5(2) accountability by design — not by assertion.

v3.0 Update: Simplified reveal flow (password removed — JWT-only auth), dedicated revoke-token Edge Function with soft revoke + iBS certification, auto-language detection (en/es based on browser locale), corrected blockchain verification links using ibs_certification_hash + ibs_network, 3-state certification badges (Certified/Certifying/Pending), user name resolution in Tokens Log, and policy rule deduplication.

Component	Status v3.0	Detail
Proxy API (FastAPI)	Production	Railway europe-west4, port 8080
PII Detection Engine	Regex MVP	DNI, IBAN, email, phone, name, health
Tokens Vault	Complete	AES-256-GCM, reveal (no password) + revoke Edge Function + iBS cert
iBS Blockchain	Operational	Fantom Opera Mainnet, sig_G5zivdkPD226
Webhook Receiver	Active	Dual lookup: audit_logs + vault_access_log
GDPR DPO Report	Complete	HTML export with TX hashes + checker links
Dashboard Realtime	Active	Supabase Realtime, 3-state ibs badge
Auto i18n	NEW v3.0	Browser locale detection en/es + localStorage override
Revoke Edge Function	NEW v3.0	Soft revoke + vault_access_log + iBS certification
NLP Engine (Presidio)	Phase 2	Microsoft Presidio + spaCy ES planned

2 The PII Gap in Enterprise AI

Enterprise adoption of AI is accelerating rapidly. However, organizations face a fundamental tension: the most valuable AI use cases — clinical notes, legal documents, HR data, financial analysis — are precisely those most likely to contain sensitive personal data.

The Three Failure Modes

- Data Exposure — Prompts sent directly to LLM providers may contain PII that is logged, used for training, or stored in third-party infrastructure outside EU jurisdiction.
- Compliance Blindness — No systematic record of what personal data was sent to which AI model, when, and by whom.
- Ungoverned Access — Individual employees connect personal API keys to LLM providers, bypassing organizational controls.

2.1 The AI Agent Risk

The next phase of enterprise AI adoption is the deployment of autonomous AI agents. Unlike simple prompt-based interactions, AI agents can initiate actions, retrieve records, generate reports, or trigger workflows autonomously.

- PII detection before execution
- Policy enforcement per data category
- Tokenization or anonymization when required
- Audit logging and blockchain evidence for every agent action

2.2 Threat Model Overview

Threat Actor	Risk	Privaro Mitigation
Internal User	Sending PII directly to external LLMs	Interception + tokenization at proxy layer
Shadow AI Usage	Personal API keys bypassing governance	Central API key management per org
AI Agent Pipelines	Automated workflows without privacy controls	Same PII detection applied to agent prompts
Data Breach	Stolen DB contains sensitive AI interactions	Only tokenized values stored — vault is encrypted

3 Architecture Overview

Privaro consists of six tightly integrated components, each with a single responsibility. The design follows a zero-trust model — no component trusts any other without verification.

Component	Technology	Responsibility
Proxy API	FastAPI (Python 3.11) Railway / Docker	Intercepts prompts, applies policies, manages tokenization flow
PII Detection Engine	Regex MVP (Phase 1) Presidio + spaCy (Phase 2)	Detection of EU PII: DNI, IBAN, email, phone, name, health records
Tokens Vault	Supabase + AES-256-GCM	Reversible pseudonymization, reveal/revoke with iBS certification
Blockchain Evidence	iBS API (iCommunity Labs) Fantom Opera Mainnet	Immutable SHA-512 certification of every audit and vault event
Policy Engine	Supabase + React	Configurable rules per entity type, provider, and regulation
Frontend Dashboard	React + Supabase Realtime	Chat, audit logs, vault admin, DPO report, policy editor, i18n

3.1 Architecture Diagram

ENTERPRISE APPLICATIONS

↓ POST /v1/proxy/protect ↑ protected_prompt

PRIVARO PROXY API (FastAPI · Railway europe-west4)

PII Detection Engine → Policy Evaluation → Tokenization

Tokens Vault (AES-256-GCM · Edge Functions: reveal-token, revoke-token)

Audit Logs (immutable · ibs_status · Realtime)

ASYNC ↓ POST /evidences ↑ webhook certified

LLM PROVIDERS: OpenAI · Anthropic · Google · Custom

iBS BLOCKCHAIN: Fantom Opera Mainnet

4 Data Flow — Request Lifecycle

The following sequence describes the complete lifecycle of a single enterprise AI request. The entire flow completes in approximately 50–100ms. Blockchain certification occurs asynchronously and does not block the response.

1. Enterprise App → Proxy API

POST /v1/proxy/protect with API key (prvr_xxxx). TLS 1.3 enforced.

2. PII Detection

Regex engine detects entities: DNI, IBAN, email, phone, full_name, health_record.

3. Policy Evaluation

Each entity evaluated against org policy rules. Action: tokenise | anonymise | block.

4. Tokenization + Audit

PII replaced with [ID-0001], [BK-0001] tokens. AES-256-GCM encrypted originals stored in tokens_vault. Audit log INSERT with ibs_status=pending.

5. Response to Client

Protected prompt returned in ~50ms. Client never blocked by blockchain operations.

6. iBS Certification (Async)

SHA-512 of audit payload posted to iBS with org signature. Evidence created on Fantom Opera Mainnet.

7. Webhook → Certified

iBS sends evidence.certified webhook. Proxy updates ibs_status=certified with TX hash + ibs_network + ibs_certification_hash. Frontend badge updates in real-time via Supabase Realtime.

5 Tokens Vault

The Tokens Vault provides reversible pseudonymization — PII is replaced by tokens in prompts, but authorized users (admin/DPO) can retrieve original values when necessary, subject to strict access controls and full audit trail.

5.1 Vault Architecture

Property	Value
Encryption Algorithm	AES-256-GCM
Nonce	12 bytes random, prepended to ciphertext
Key Management	Per-organization — ENCRYPTION_KEY (64 hex chars)
Key ID	key-v1 (rotation-safe reference)
Access Control	admin and dpo roles only (RLS enforced)
Reveal Authorization	Valid JWT + role verification via Edge Function (no password) [UPDATED v3.0]
Revoke Action	Soft revoke via revoke-token Edge Function — is_reversible=false, expires_at=now() [UPDATED v3.0]
iBS Certification	Reveal + Revoke events certified on Fantom Opera Mainnet

5.2 Vault Event Lifecycle [UPDATED v3.0]

- Tokenization: proxy/protect detects PII → encrypts original → stores token in tokens_vault
- Reveal: DPO/admin clicks Reveal → reveal-token Edge Function → JWT + role check (no password required) → AES decrypt → log in vault_access_log → certify in iBS
- Revoke: Admin clicks Revoke → revoke-token Edge Function → soft revoke (is_reversible=false, expires_at=now) → log action="revoked" in vault_access_log → certify in iBS
- iBS Certification: Both reveal and revoke events generate iBS evidence on Fantom Opera Mainnet with org signature

5.3 Reveal Flow [UPDATED v3.0]

v3.0 Change: Password confirmation removed. The reveal-token Edge Function now authenticates solely via JWT token + role verification (admin/dpo). This simplifies the UX while maintaining security through Supabase's auth layer.

Flow: Click Reveal button → Edge Function validates JWT → checks user_roles → fetches token from tokens_vault → AES-256-GCM decrypt → returns value → logs access in vault_access_log → updates reversal_count.

5.4 Revoke Flow [UPDATED v3.0]

v3.0 Change: Revocation now uses a dedicated revoke-token Edge Function instead of direct client-side DELETE. This ensures proper audit logging and iBS certification even when RLS would prevent client-side operations.

Flow: Click Revoke → AlertDialog confirmation → revoke-token Edge Function (service role) → UPDATE is_reversible=false, expires_at=now → INSERT vault_access_log action="revoked" → certify in iBS → token removed from Active Tokens list.

6 Database Schema

Privaro uses Supabase (PostgreSQL 15) with Row Level Security (RLS) enforced on all tables. The org_id field on every table guarantees strict multi-tenant isolation.

Table	Status	Responsibility
organizations		Root multi-tenant model. Stores plan, DPO email, data region, pipeline limits.
users / profiles		Supabase Auth + enterprise roles (admin, dpo, developer, viewer).
pipelines		AI integrations. Tracks provider, model, policy set, privacy metrics.
policy_rules	UPDATED	Per-org rules per GDPR article. Deduplication check before insert. [v3.0]
audit_logs		Immutable PII events. 5 ibs_* columns. UPDATE restricted to ibs_* via RLS.
pii_detections		Granular entity records — position, confidence, detector, token reference.
tokens_vault		AES-256-GCM encrypted tokens. is_reversible + access_roles + iBS fields.
vault_access_log	UPDATED	Audit trail for reveal/revoke. ibs_evidence_id + ibs_certification_hash + ibs_network. [v3.0]
api_keys		SHA-256 hashed org keys. Plaintext never stored.
ibs_sync_queue		Retry resilience for blockchain certification. Max 3 retries + DPO alert.
conversations		Chat sessions. Stores tokenized content only — no raw PII.
llm_providers		LLM provider catalog per org. Admin-configurable.

7 Blockchain Evidence Layer (iBS)

Privaro partners with iBS (iCommunity Blockchain Solutions) to provide cryptographic proof that audit records have not been tampered with. A database audit log, no matter how well secured, can theoretically be altered by a database administrator. A blockchain-anchored hash cannot.

7.1 Certification Details

Property	Value
Hash Algorithm	SHA-512 of complete audit_log JSON, base64-encoded
Blockchain Network	Fantom Opera Mainnet (EVM-compatible, low-cost, high-throughput)
Evidence API	POST https://api.icommunitylabs.com/v2/evidences
Organization Signature	sig_G5zivdkPD226iTWDCYKBuh (icommunity_labs)
Verification URL	https://checker.icommunitylabs.com/check/{ibs_network}/{ibs_certification_hash} [UPDATED v3.0]
Certification Mode	Asynchronous — webhook evidence.certified callback
Retry Resilience	ibs_sync_queue: max 3 retries, DPO alert on exhaustion
Evidence ID Format	evd_ + 22 alphanumeric characters
Events Certified	PII audit_logs + vault reveals + vault revocations

7.2 Organization Signature Model

Privaro uses a single organization-level iBS signature rather than per-user signatures. This is architecturally aligned with GDPR — the organization is the Data Controller and bears accountability responsibility, not individual employees.

- One KYC verification per organization (admin/DPO completes)
- All evidence certified under the org signature — consistent chain of accountability
- Employee rotation does not affect compliance posture
- Audit trail links user_id to each event internally while blockchain evidence is org-level

7.3 Vault Access Certification

Blockchain certification extends beyond PII processing events to vault access events. Every time a DPO or admin reveals or revokes a tokenized value, that action is independently certified on Fantom Opera Mainnet — providing immutable proof of who accessed what data and when.

Event	iBS Title Format	File Name
PII Detect/Protect	privaro_{audit_log_id[:16]}	pii_audit_{entity_types}.json
Vault Reveal	vault_reveal_{token_id[:12]}	vault_reveal_{entity_type}_{token}.json
Vault Revoke	vault_revoke_{token_id[:12]}	vault_revoke_{entity_type}_{token}.json

7.4 Blockchain Verification Links [NEW v3.0]

v3.0 Change: All blockchain verification links now use ibs_certification_hash and ibs_network (not ibs_evidence_id) to construct the checker URL. This applies to Audit Logs, Tokens Log (vault_access_log), DPO Report, and CSV export.

Correct URL format:

https://checker.icommunitylabs.com/check/{ibs_network}/{ibs_certification_hash}

Example: https://checker.icommunitylabs.com/check/fantom_opera_mainnet/0xab8fac2f...

The Tokens Log (vault_access_log) displays a 3-state badge:

- Certified ⛓ — ibs_certification_hash exists → green badge with link to checker
- Certifying… — ibs_evidence_id exists but no hash yet → amber badge
- Pending — no evidence ID → amber badge

8 GDPR Export & DPO Report

Privaro generates a complete GDPR Art.5(2) Accountability Report directly from the dashboard. The report includes all certified events with blockchain TX hashes and public verification links, ready for submission to AEPD, ICO, or internal auditors.

Export Formats

- CSV Export: All audit_log fields including ibs_evidence_id, ibs_certification_hash, ibs_network, ibs_certified_at, and constructed blockchain_checker_url. Filterable by severity, status, date range, and entity type.
- DPO Report (HTML/PDF): Structured accountability report with executive summary, legal basis references, blockchain evidence log per event, and GDPR declaration. Includes TX hash and public checker link for each certified event. Printable as PDF from the browser.

Report Contents

- Executive Summary: Total events, certification rate, entities protected, pipelines used
- Legal Basis: GDPR Art.5(2), Art.25, Art.32 with specific technical measures documented
- Blockchain Evidence Log: Per-event: timestamp, entity type, action, pipeline, evidence ID, TX hash, checker URL
- GDPR Declaration: Signed statement of compliance with accountability references

9 Regulatory Compliance

GDPR — EU General Data Protection Regulation

- Art.5(1)(f): Integrity and confidentiality — AES-256-GCM + TLS 1.3
- Art.5(2): Accountability — blockchain-certified evidence per event
- Art.25: Privacy by Design — interception before LLM, not after
- Art.30: Records of processing — immutable audit_logs table
- Art.32: Technical measures — encryption + pseudonymization + access control
- Art.9: Special categories — health_record entity type with critical severity

HIPAA

- PHI detection: patient names, medical record numbers, diagnoses, dates of birth
- Minimum necessary standard via configurable policy rules
- Audit controls: blockchain-certified log of all PHI access

PSD2 — Payment Services Directive 2

- IBAN and card numbers detected and tokenized automatically
- Financial identifiers never reach LLM providers

EU AI Act

- High-risk AI systems: fundamental rights impact assessment support
- Transparency: per-entity action in audit logs
- Data governance: centralized policy enforcement per pipeline

10 Enterprise Use Cases

Legal Document Review

Law firms use AI to analyze contracts and legal documents. Privaro ensures that client identities, addresses, and confidential clauses are tokenized before reaching the AI model.

Healthcare Documentation

Clinical notes contain patient names, identification numbers, and diagnoses. Privaro detects and pseudonymizes PHI before AI processing — ensuring HIPAA and GDPR Art.9 compliance.

Financial Analysis

Financial institutions use AI to analyze portfolios and transaction data. Privaro automatically detects IBAN numbers, card references, and financial identifiers, replacing them with reversible tokens.

Customer Support Automation

AI assistants analyzing customer emails frequently encounter personal data. Privaro ensures all customer identifiers are protected before AI analysis.

Enterprise AI Agents

Internal copilots integrated with CRM, ERP, or HR systems safely query enterprise data without exposing sensitive records.

11 Role & Access Model [UPDATED v3.0]

Privaro implements a four-tier role model with cumulative permissions. Row Level Security in Supabase enforces these boundaries at the database level — not just the application layer.

Role	Typical User	Key Capabilities
viewer	Business user	Secure chat, view own conversation history, dashboard metrics
developer	Engineer	Above + create/configure AI pipelines, manage technical settings
dpo	Data Protection Officer	Above + reveal tokens (JWT-only, no password), export GDPR reports, DPO dashboard [UPDATED v3.0]
admin	IT Admin, CTO	Above + user management, LLM catalog, API keys, billing, org settings, revoke tokens via Edge Function [UPDATED v3.0]

12 Internationalization (i18n) [NEW v3.0]

NEW in v3.0 — Privaro automatically detects the user's browser locale (navigator.language) to serve the landing page in the appropriate language. All Spanish-speaking countries (es-*) see the Spanish version; all others see English.

Implementation

- Custom LanguageContext with t() function — no external i18n library required
- Detection: navigator.language starts with "es" → Spanish, else English
- Persistence: manual language toggle saved to localStorage (key: privaro-lang)
- Priority: localStorage override > browser locale detection
- Supports: en (English) and es (Spanish) for all landing page content
- App dashboard currently English-only (admin/technical interface)

13 Competitive Landscape

Capability	Privaro	Block AI	Accept Risk	Build In-house	Generic DLP
Transparent to users	✓		~	~	
Real-time PII detection	✓	—	~		
Reversible tokenization	✓	—	~	—	
Blockchain audit proof	✓	—	—	—	
Vault access certification	✓	—	—	—	
GDPR DPO report	✓	—	—	~	
GDPR Art.5(2) ready	✓	—	~		
Multi-LLM support	✓		~		
Auto i18n (en/es)	✓ NEW	—	—	—	—
EU data residency	✓		—	~	
Time to deploy	< 1 day	< 1 day	0 days	6-18 months	1-3 months

14 SLAs & Technical Guarantees

Performance

Property	Guarantee
Proxy latency overhead	< 50ms p50, < 100ms p99
API availability	99.9% uptime SLA (enterprise plan)
Throughput	1,000 requests/minute per pipeline (scalable)
Cold start	< 2 seconds (Railway always-on deployment)

Security

Property	Guarantee
Encryption in transit	TLS 1.3 enforced on all connections
Encryption at rest	AES-256-GCM for tokens, per-org key segmentation
API key security	SHA-256 hashed — plaintext never stored
Audit log immutability	UPDATE restricted to ibs_* columns only via RLS
Vault access control	admin/dpo roles only via Edge Function + JWT verification (no password) [UPDATED v3.0]

Blockchain Evidence

Property	Guarantee
Certification time	Typically 30–120 seconds (Fantom Opera Mainnet finality)
Events certified	PII audit_logs + vault reveals + vault revocations
Retry resilience	Automatic retry x3 via ibs_sync_queue, DPO alert on exhaustion
Public verifiability	Any certified hash verifiable at checker.icommunitylabs.com
Org signature	sig_G5zivdkPD226iTWDCYKBuh (icommunity_labs KYC verified)

15 Roadmap [UPDATED v3.0]

Phase	Name	Deliverables
Phase 0–1	Foundation	Supabase schema + RLS, Lovable dashboard, FastAPI proxy, /proxy/detect and /proxy/protect
Phase 2	NLP Engine (Regex MVP)	Regex detection for DNI, NIE, IBAN ES, email, phone, full_name, health_record
Phase 3	Tokens Vault	AES-256-GCM tokenization with per-org key segmentation, reveal/revoke Edge Functions
Phase 4	Policy Engine + Admin	Full CRUD policy rules with deduplication, sector presets, LLM provider catalog, user management

Phase 5	Blockchain Evidence (iBS)	POST /evidences, webhook receiver dual-lookup, ibs_sync_queue, Fantom Opera Mainnet
Phase 6	GDPR Export + DPO Report	CSV export with blockchain fields, HTML DPO report with TX hashes and checker links
Phase 6.5	UX & Hardening [NEW v3.0]	Simplified reveal (no password), revoke Edge Function, auto i18n, blockchain link corrections, 3-state badges, policy deduplication
Phase 7	Pilot — First Enterprise Client	Client onboarding, E2E testing, risk and coverage report, blockchain certification
Phase 8	NLP Engine Upgrade	Microsoft Presidio + spaCy es_core_news_lg — semantic entity detection
Phase 9	Enterprise AI Governance Platform	AI usage monitoring, risk scoring, automated compliance reporting, agent governance

16 Architecture Principles

1. Interception before inference

Privacy controls are applied at the network layer — before any data reaches an AI model. This is architecturally superior to post-processing or application-level filtering.

2. Zero raw PII exposure

No plaintext personal data is ever transmitted to an external AI provider. Tokenization occurs within Privaro's trusted boundary. Original values are stored exclusively in the encrypted Tokens Vault with per-org key segmentation.

3. Verifiable compliance evidence

Audit records are not merely stored — they are cryptographically certified on a public blockchain. Compliance is demonstrable to regulators, auditors, and data subjects independently of Privaro's own infrastructure.

4. Provider-agnostic AI governance

Privaro enforces the same governance rules regardless of which LLM provider is used. Organizations can switch between OpenAI, Anthropic, Google, or private models without changing their compliance posture.

5. Minimal operational friction

Privaro is transparent to end users — no workflow changes, no new interfaces to learn. The ~50ms proxy latency is imperceptible in practice. Privacy protection should not come at the cost of productivity.

Ready to evaluate Privaro? Request a technical demo or integration consultation with the iCommunity Labs team.

privaro.io · hello@icommunity.io · Version 3.0 · March 2026
© 2026 iCommunity Labs · privaro.io · Public document — freely shareable